

研究生专业理论核心课程

Web 安全



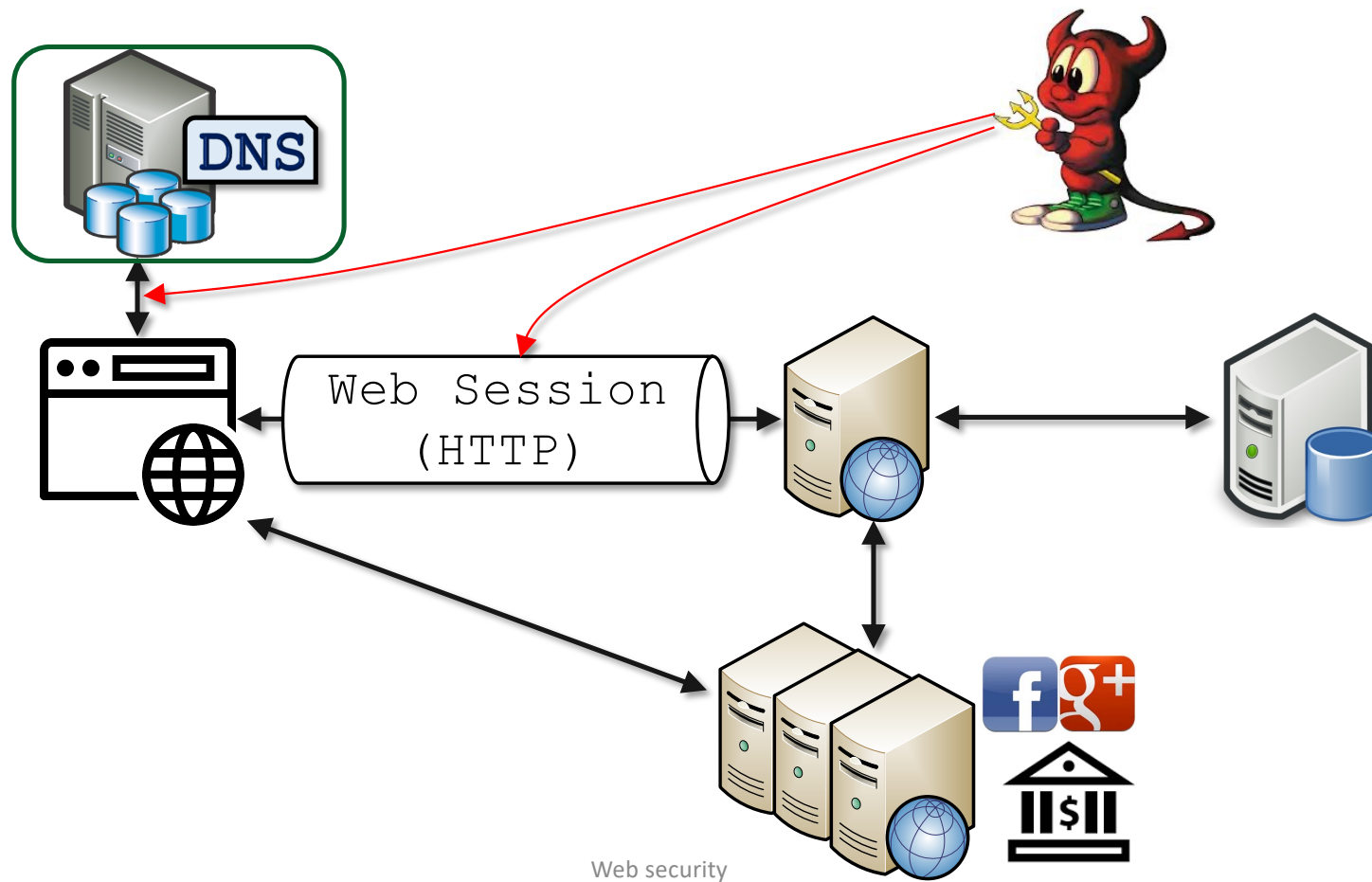
北京航空航天大学
BEIHANG UNIVERSITY

Network-level Attacks and Secure Channel

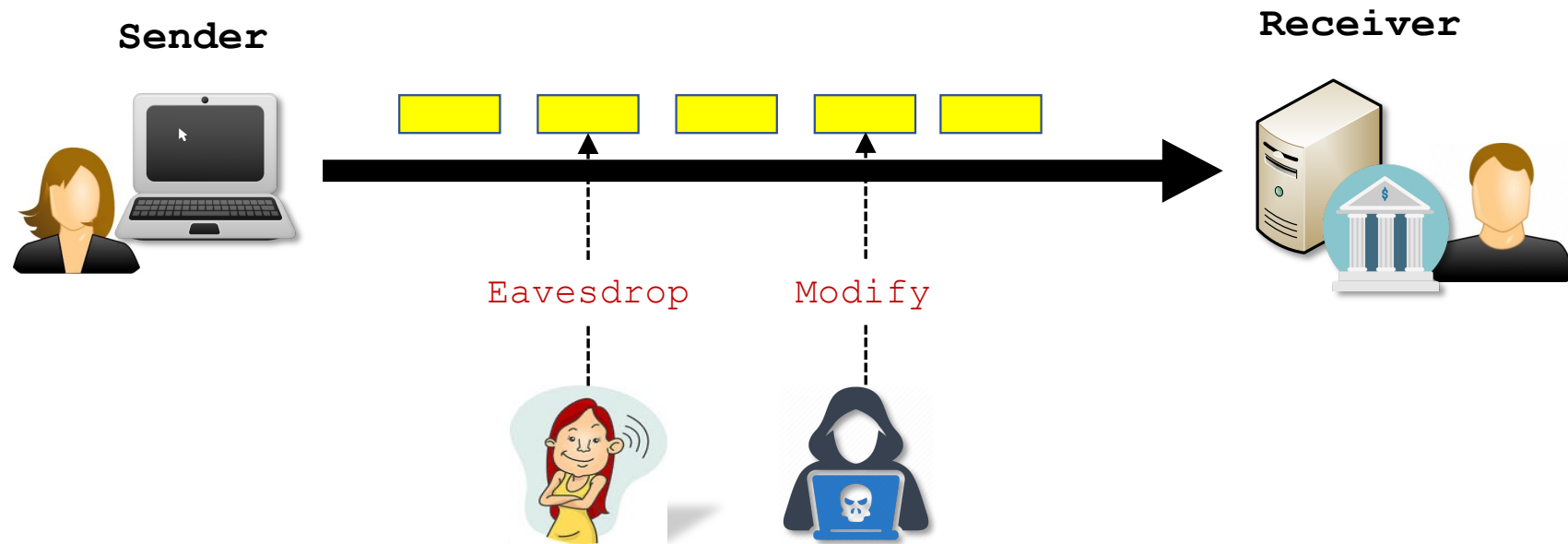
39113104: Web Security

Jian Mao

Network Threats to Web

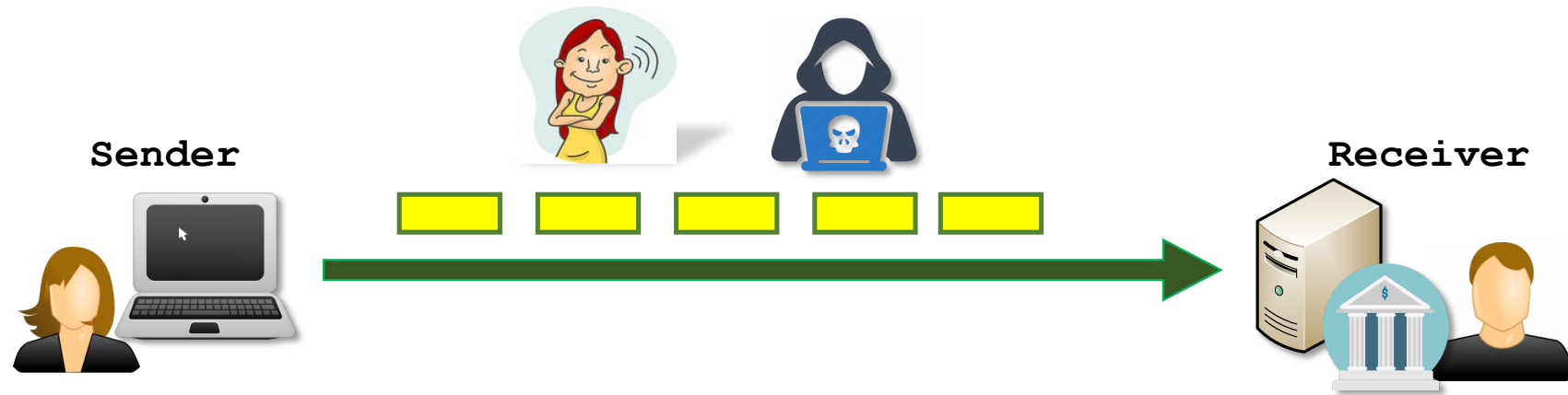


Network-level Attackers



Intercept Traffic between Alice and ANY website!

Let's Conceptualize: Defining A Secure Channel



- A Secure Channel establishes between 2 programs, a data channel that has:
 - C**onfidentiality
 - I**ntegrity
 - A**uthentication

} **Crypto-aided**
- against a computationally-bounded “network attacker”
[Dolev-Yao-1983]

Outline

- Crypto Basics
 - Symmetric ciphers (Single-key)
 - Asymmetric ciphers (Public-key)
 - Hash Functions
- Domain Name System (DNS)
 - How DNS works
 - DNS cache poisoning
- HTTP Protocol: a quick recap
- Secure Channel on the Internet: HTTPs
 - Protocols
 - Attacks and Defenses

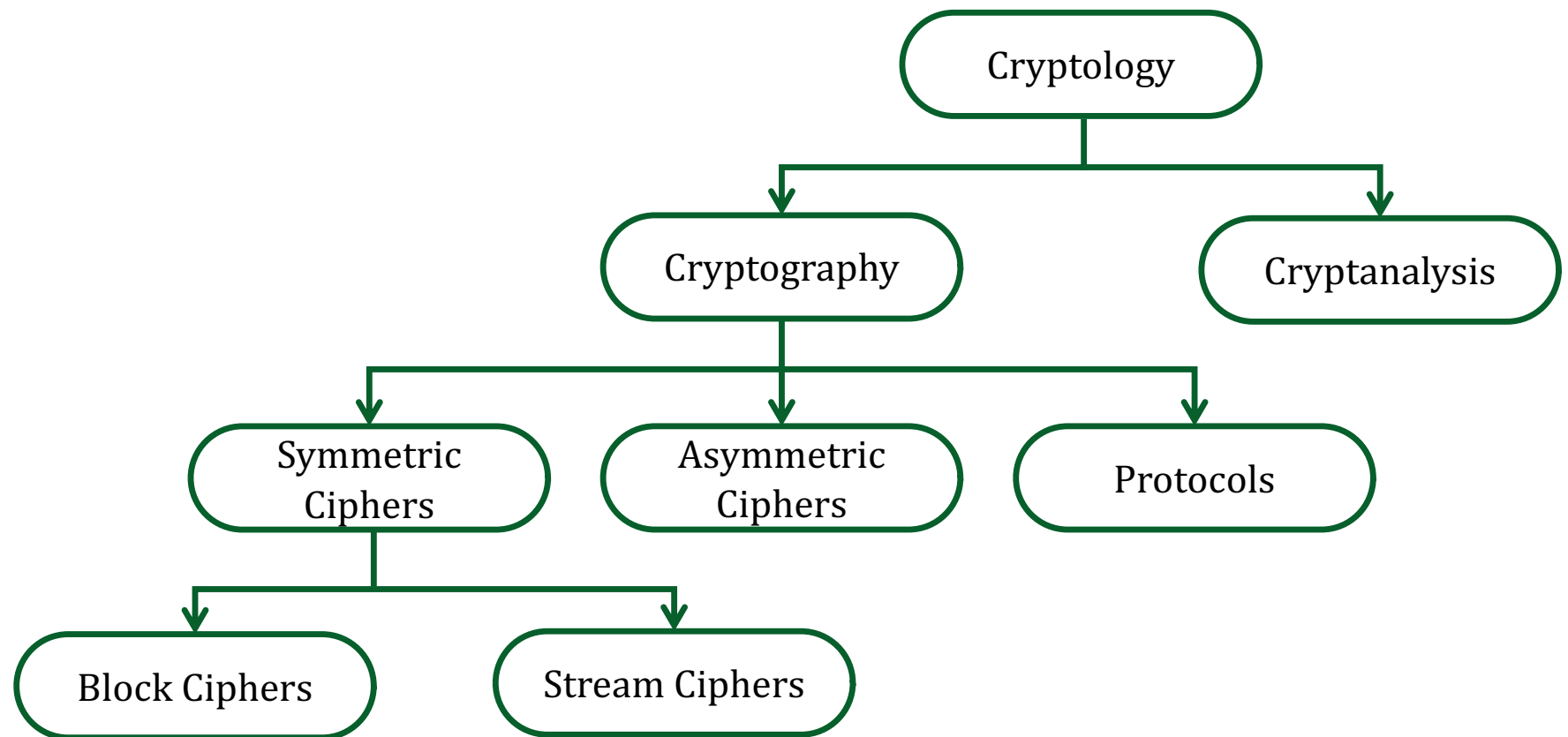
Crypto Basics: Recap

Symmetric ciphers

Asymmetric ciphers

Hash Function

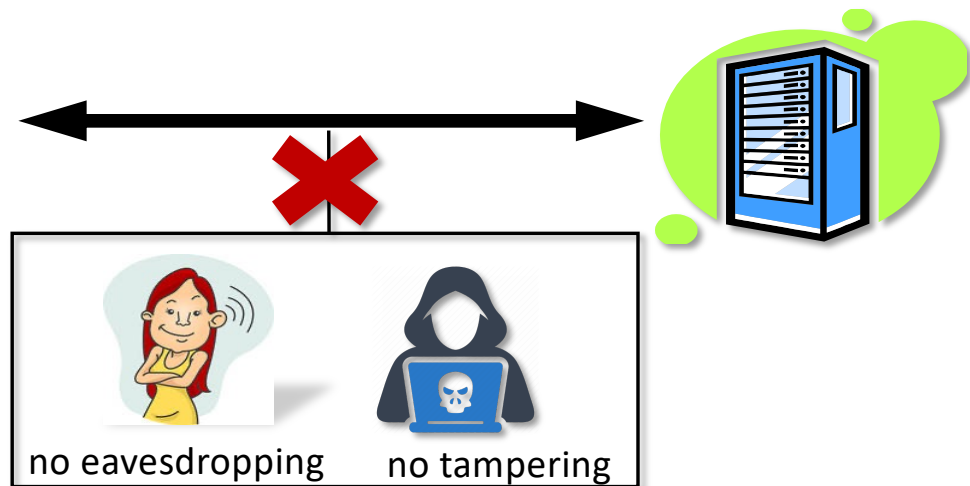
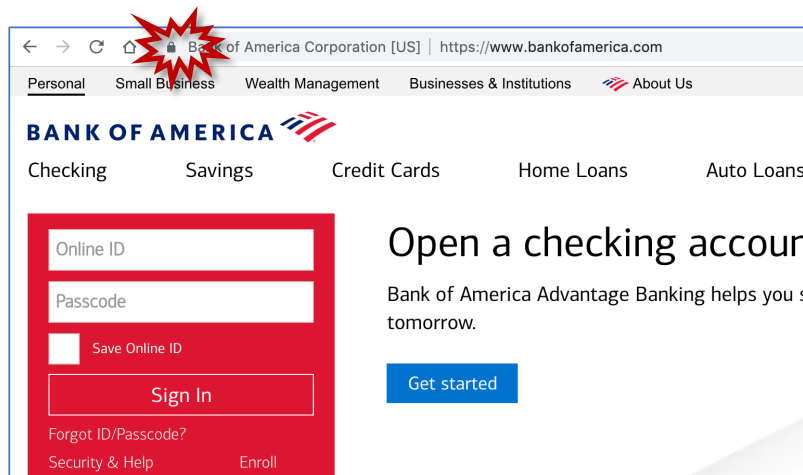
Crypto



Cryptography

Goal 1: Secure communication

(protecting data in motion)

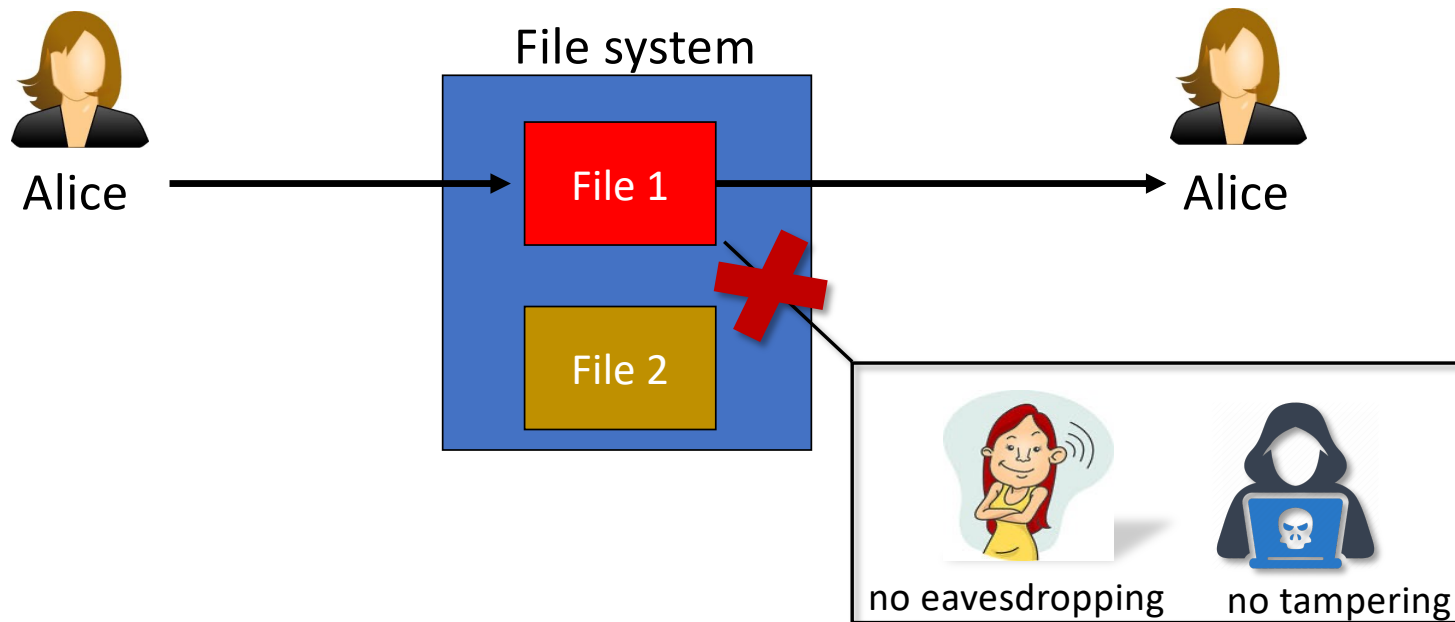


Web security

Cryptography

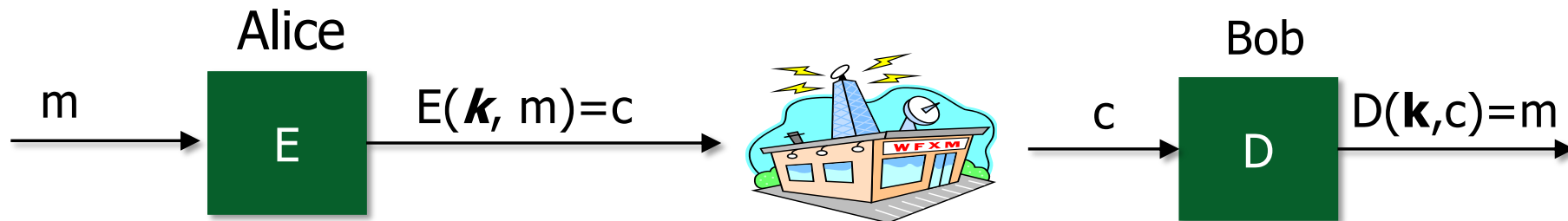
Goal 2: Protect files

(protecting data at rest)



Symmetric Cipher

Bob and **Alice** Share a secret, the key k .



E, D – Encryption alg., Decryption alg.
 k : secret key (e.g., 128 bits)
 m, c : plaintext, ciphertext

- Encryption Algorithms E, D are publicly known.

One-Time-Pad



Q: Is it possible that build a **perfect secrecy** algorithm with the key *shorter* than the message?

Theorem: Perfect secrecy requires $|K| \geq |M|$

Key (n bits)

Plaintext (n bits) $\oplus$

Ciphertext (n bits)

Perfect Secrecy

In practice, we usually shoot for *computational security*.

Notion 1: “enough security” –time, cost
Notion 2: no polynomial time algorithm could break the cipher

One-Time-Pad



More Practical?

Idea: replace “random” key
by “pseudorandom” key

Key (n bits)

Plaintext (n bits) $\oplus$

Ciphertext (n bits)

Perfect Secrecy

Stream Cipher

Key (k bits)

Pseudorandom
Generator G

$G(\text{Key})$ (n bits)

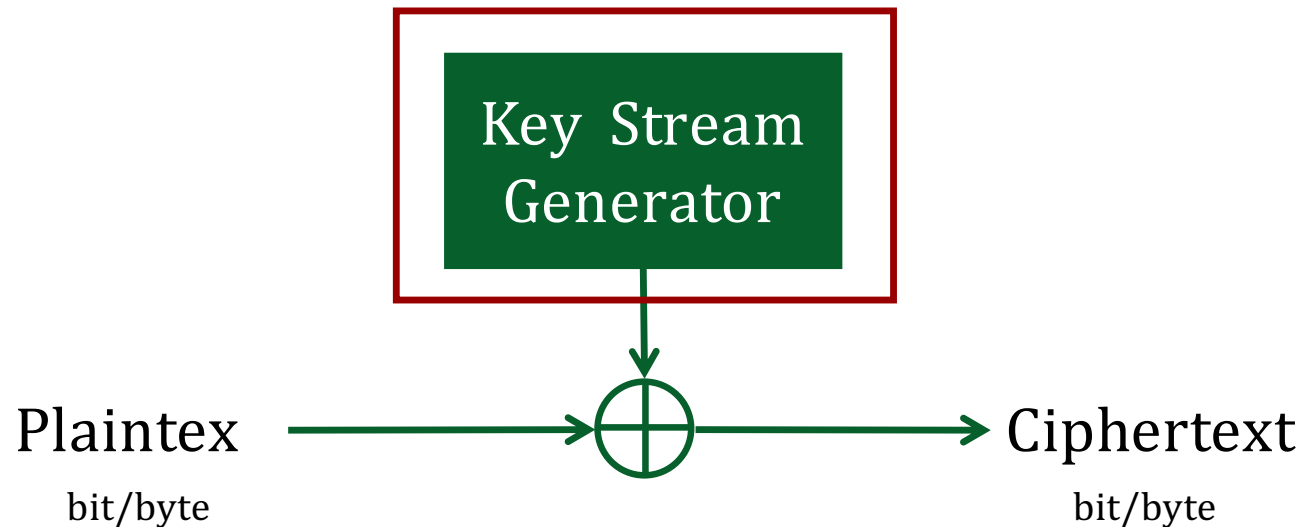
Plaintext (n bits) $\oplus$

Ciphertext (n bits)

Computational Security

Stream Cipher

What is a Stream Cipher?



Canonical examples:

1. A5/1—GSM
2. RC4 –SSL/TLS, WEP, WPA...

A5/1: Shift Registers

- A5/1 uses 3 *shift registers*

- X: 19 bits ($x_0, x_1, x_2, \dots, x_{18}$)
- Y: 22 bits ($y_0, y_1, y_2, \dots, y_{21}$)
- Z: 23 bits ($z_0, z_1, z_2, \dots, z_{22}$)

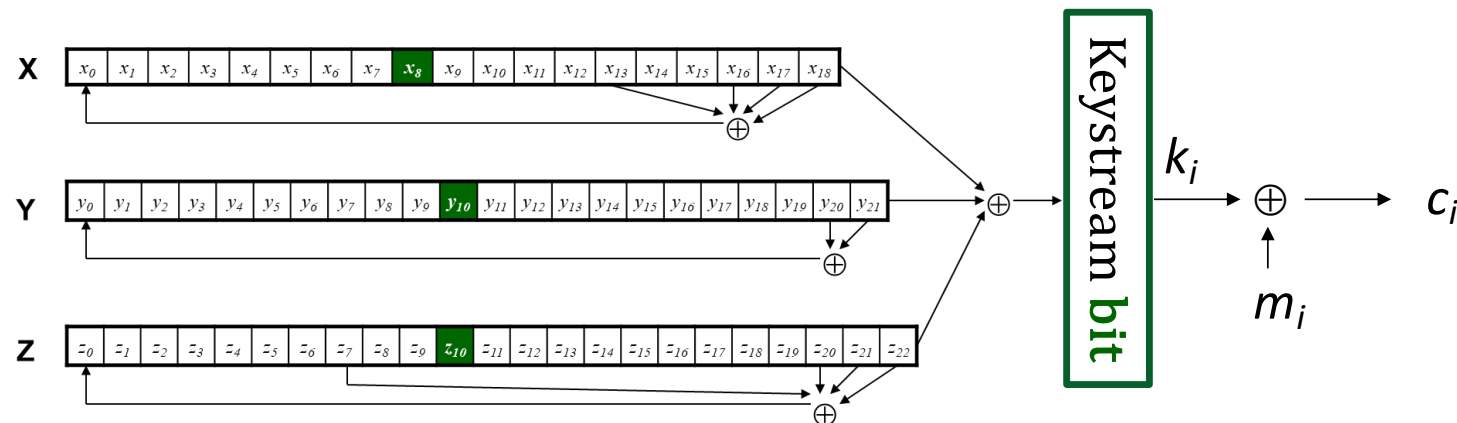
Each variable here is a single bit

Key is used as **initial fill** of registers

Each register steps (or not) based on $\text{maj}(x_8, y_{10}, z_{10})$

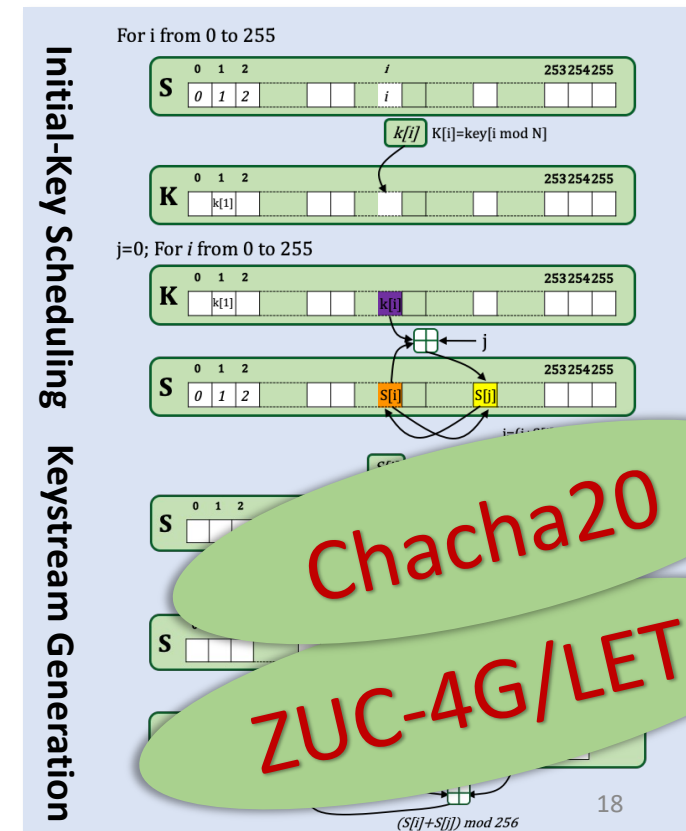
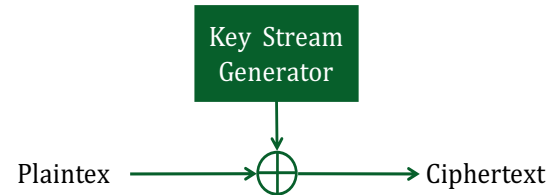
Keystream bit is XOR of rightmost bits of registers

$$m = \text{maj}(x_8, y_{10}, z_{10})$$



RC4

- A self-modifying lookup table
- Table always contains a permutation of the byte values 0,1,...,255
- Initialize the permutation using key
- At each step, RC4 does the following
 - Swaps elements in current lookup table
 - Selects a keystream byte from table
- Each step of RC4 produces a **byte**
 - Efficient in software
- Each step of A5/1 produces only a bit
 - Efficient in hardware



Dangers in using stream cipher: Two Time Pad is Insecure



- Two Time Pad:
 - $c_1 = m_1 \oplus k$
 - $c_2 = m_2 \oplus k$
- Eavesdropper gets c_1 and c_2 .
What is the problem?

Enough redundancy in ASCII
(and English) that
 $m_1 \oplus m_2$ is enough
to know m_1 and m_2

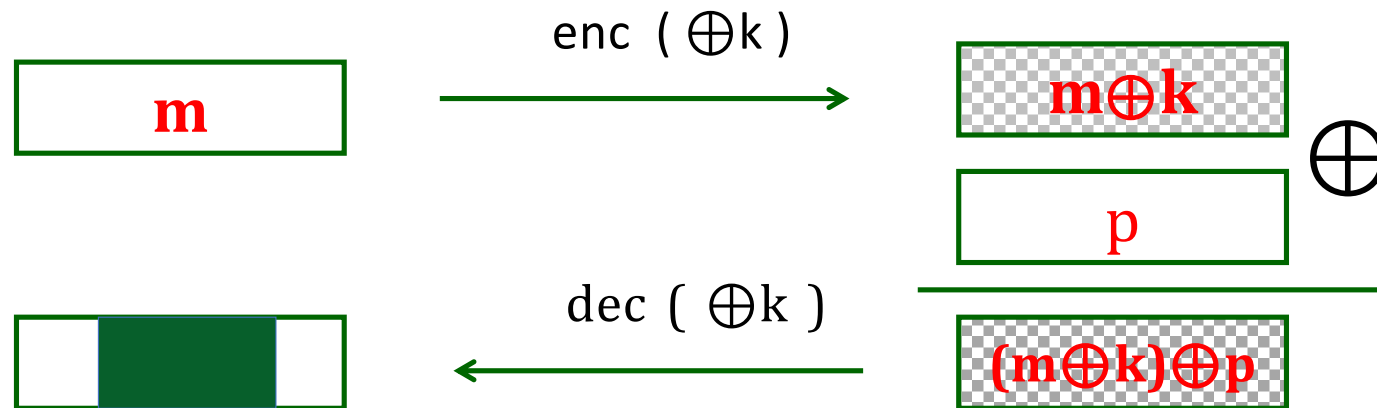
Hmm.. m_1 is AP's ID...

$$c_1 \oplus c_2 = m_1 \oplus m_2$$

m_2



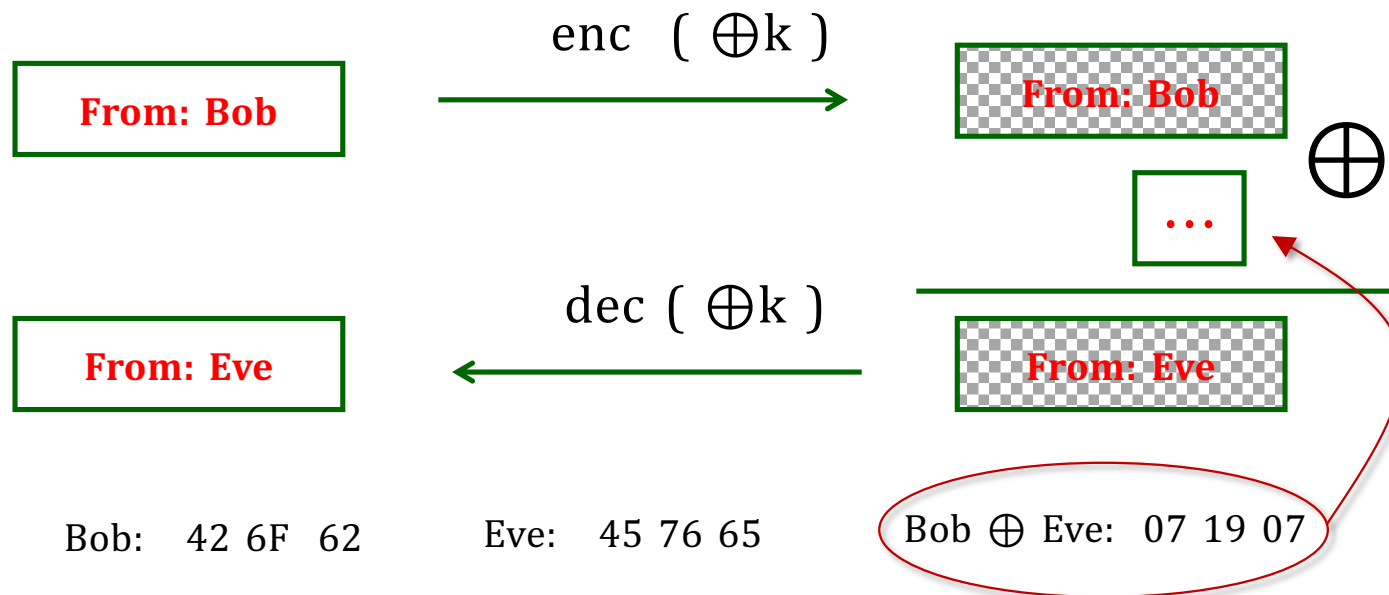
Dangers in using stream cipher: No integrity



Modifications to ciphertext are **undetected** and have **predictable** impact on plaintext



Dangers in using stream cipher: No integrity



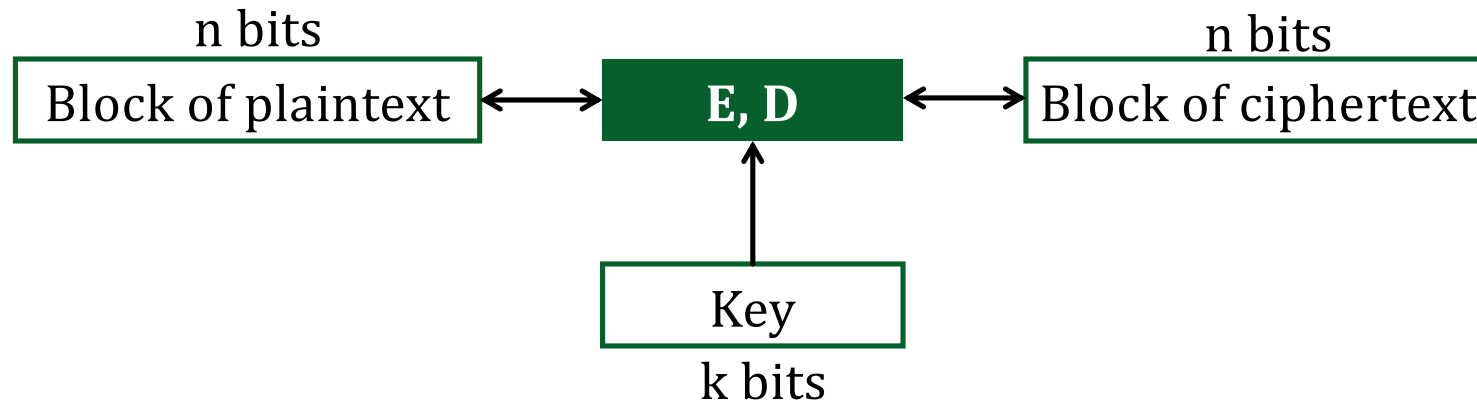
Modifications to ciphertext are undetected and have **predictable** impact on plaintext

Discussion

- Stream ciphers were popular in the past
 - **Efficient in hardware**
 - Speed was needed to keep up with voice, etc.
 - Today, processors are fast, so software-based crypto is usually more than fast enough
- Future of stream ciphers?
 - Shamir declared “the death of stream ciphers”
 - May be greatly exaggerated...

Block Cipher

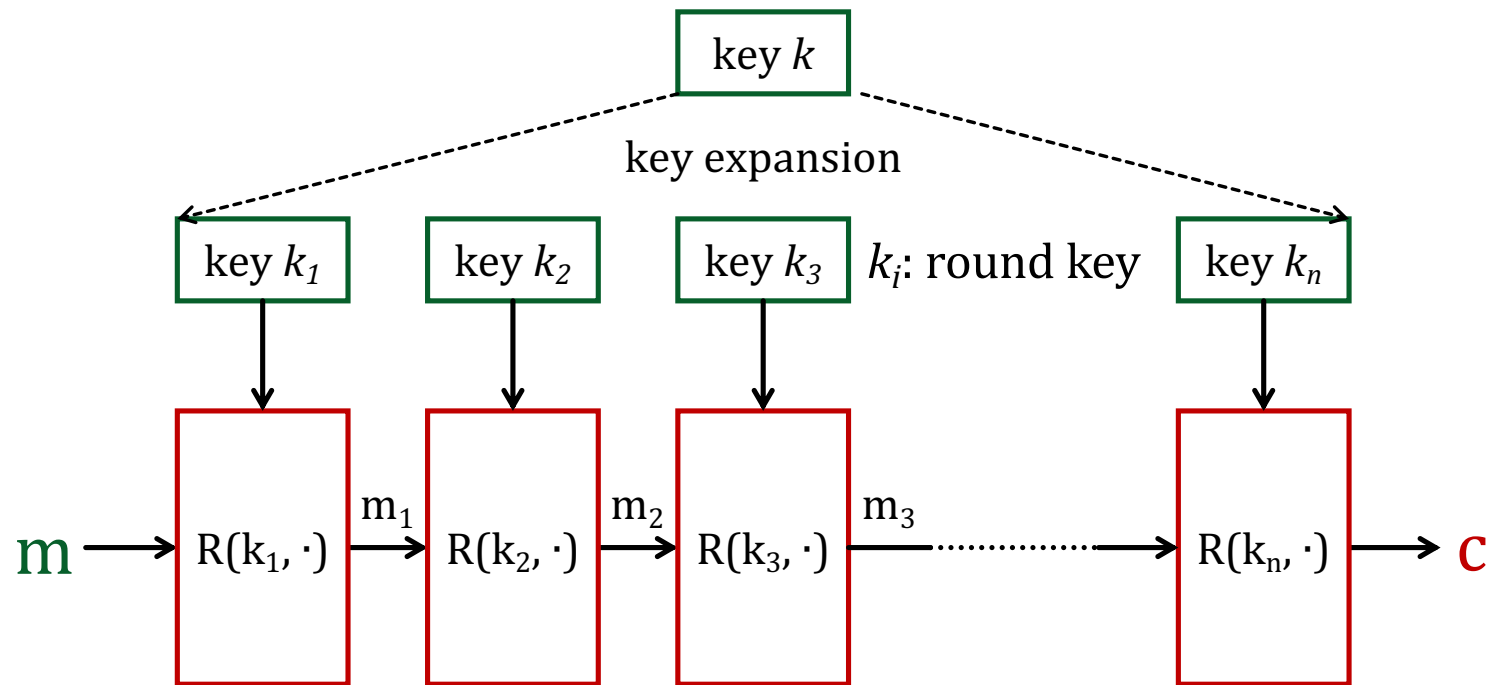
What is a block cipher?



Canonical examples:

1. 3DES: $n = 64$ bits, $k = 168$ bits
2. AES: $n = 128$ bits, $k = 128, 192, 256$ bits

Block ciphers built by iteration



$R(k, m)$ is called a round function

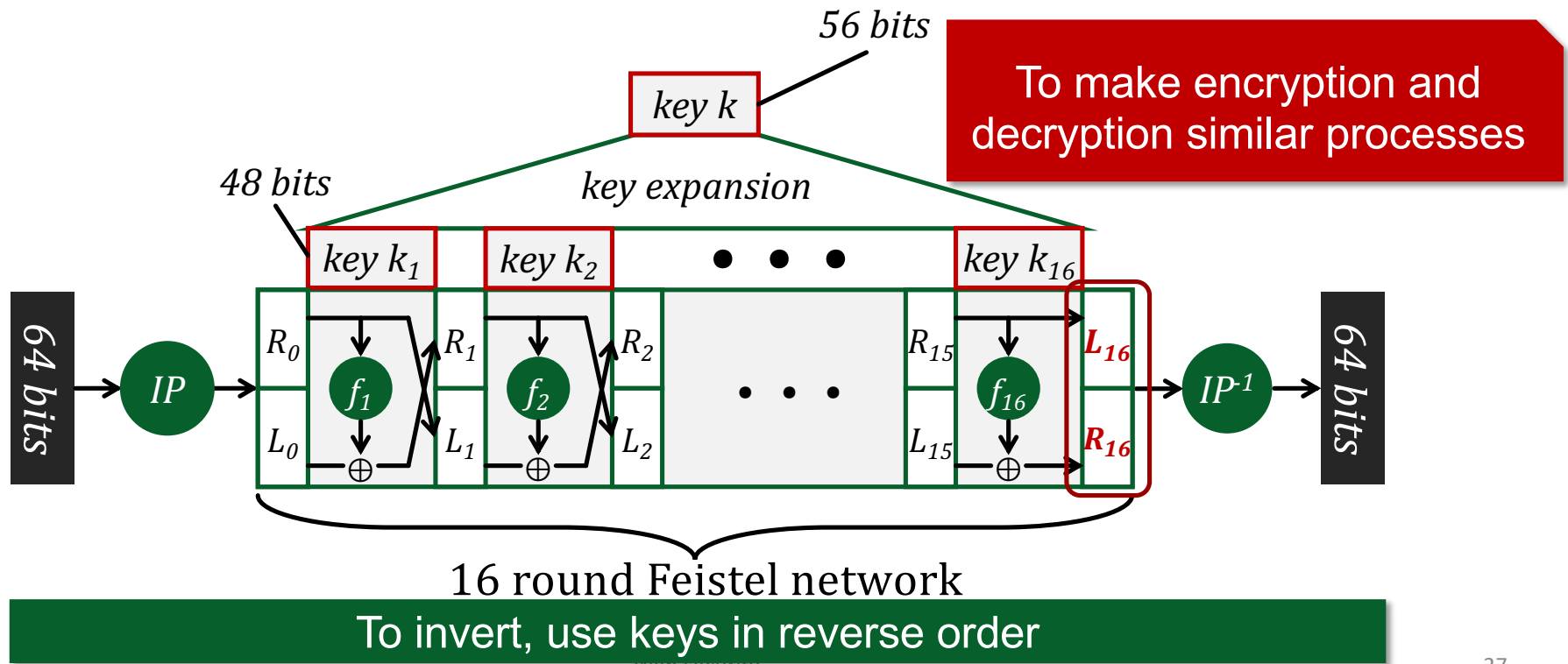
Ex: 3DES ($n=48$), AES128 ($n=10$)

Data Encryption Standard (DES)

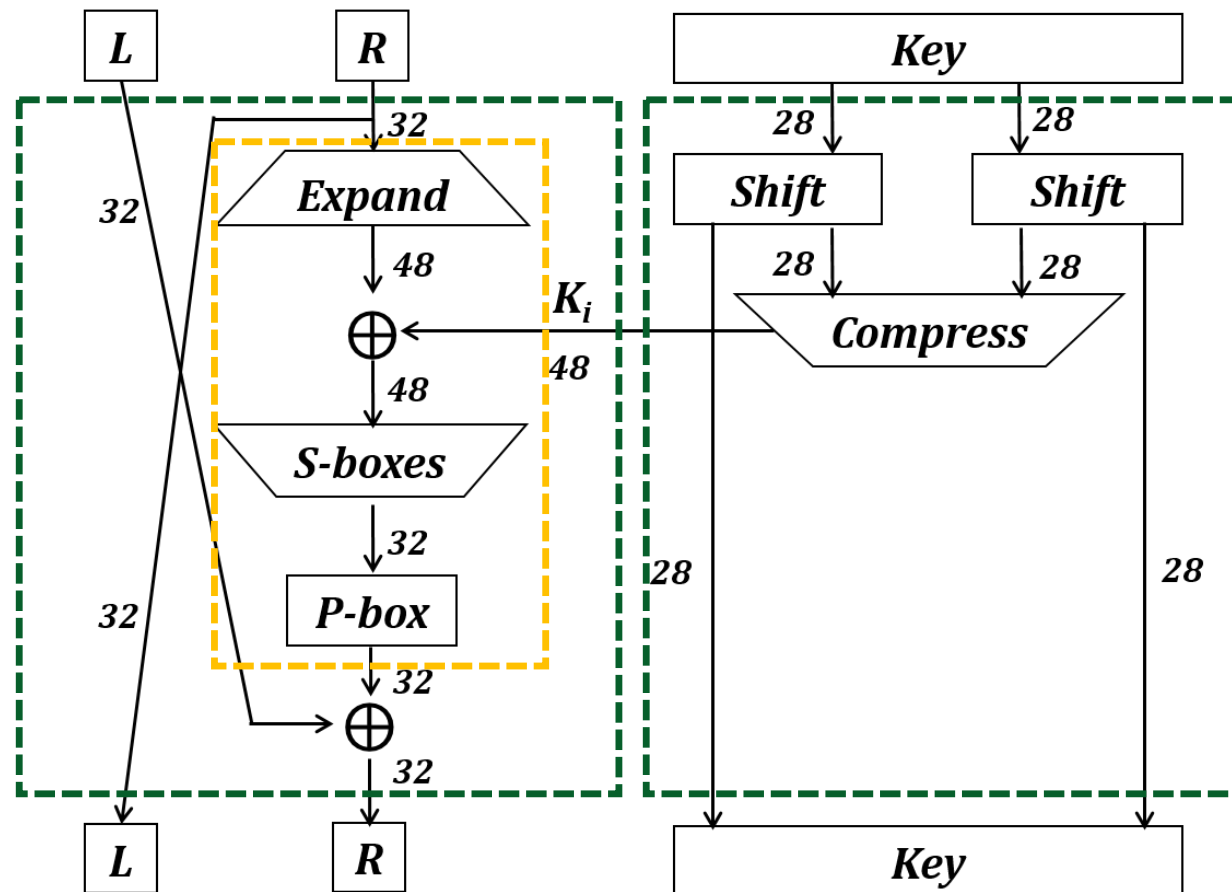
- DES is the archetypal block cipher
 - fixed-length string of plaintext bits
 - cipher-text bit-string of the same length.
- Block size is 64 bits.
- The key ostensibly consists of 64 bits
 - Only 56 of these are actually used by the algorithm.
 - 8 bits are used solely for checking parity, and are thereafter discarded.
 - Hence the effective key length is 56 bits.

DES: 16 round Feistel network

$$f_1, \dots, f_{16} : \{0, 1\}^{32} \rightarrow \{0, 1\}^{32} \text{ and } f_i(x) \Rightarrow \mathbf{F}(k_i, x) \begin{cases} R_i = f_i(R_{i-1}) \oplus L_{i-1} \\ L_i = R_{i-1} \end{cases}$$



One Round of DES



Security of DES

- Security depends heavily on S-boxes
 - Everything else in DES is linear
- Thirty+ years of intense analysis has revealed no “back door”
- Attacks, **essentially exhaustive key search**
- Inescapable conclusions
 - Designers of DES knew what they were doing
 - Designers of DES were way ahead of their time

Secure DES

- Today, 56 bit DES key is too small
 - Exhaustive key search is feasible
- But DES is everywhere, so what to do?
 - Solution: use Multi-encryption to expand the length of the key
 - Make full use of the design of DES
 - Save the investment in software and devices



2-DES?

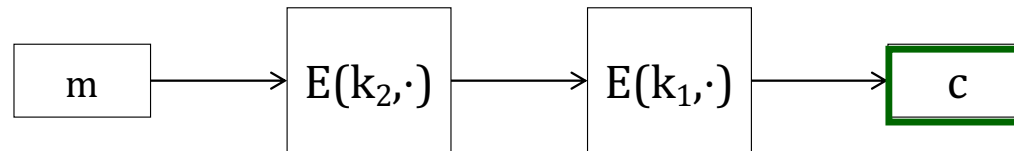
NO!



Why not 2DES?

- Define $2E((k_1, k_2), m) = E(k_1, E(k_2, m))$

key-len = 112 bits for 2DES



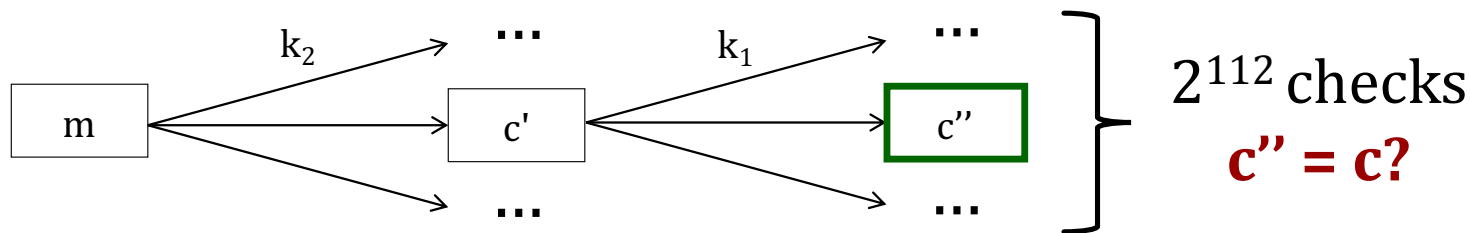
More clever?

Naïve Attack: $M = (m_1, \dots, m_{10})$, $C = (c_1, \dots, c_{10})$.

For each $k_2 \in \{0, 1\}^{56}$:

For each $k_1 \in \{0, 1\}^{56}$:

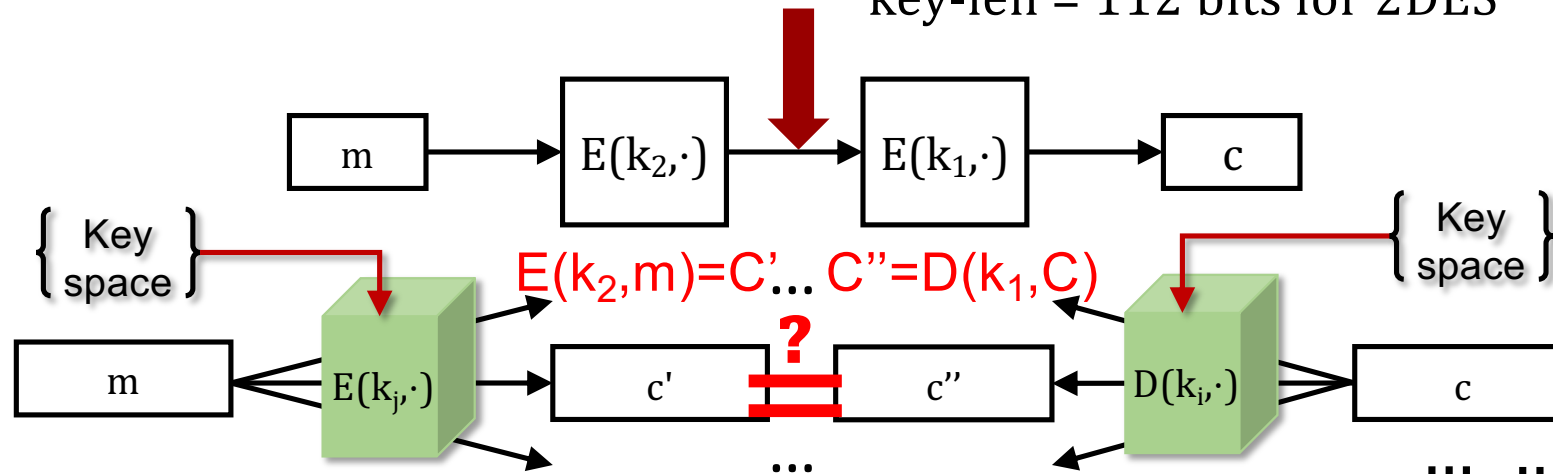
if $E(k_2, E(k_1, m_i)) = c_i$ then (k_2, k_1)



Web security

Meet in the middle attack

- Define $2E((k_1, k_2), m) = E(k_1, E(k_2, m))$
key-len = 112 bits for 2DES



- Idea: key found when $c' = c''$: $E(k_i, m) = D(k_j, c)$
Time = $256 \log(256) + 256 \log(256) < 2^{63} \ll 2^{112}$

Strengthening DES

Method : **Triple-DES**

Key-len=112bits

Let $E : K \times M \rightarrow M$ be a block cipher **Enough**

Define $3E: K^3 \times M \rightarrow M$ as: $k_1 = k_3 \Rightarrow 2k\text{-}3DES$

$$3E((k_1, k_2, k_3), m) = E(k_1, D(k_2, E(k_3, m)))$$

3DES

- Key-size: $3 \times 56 = 168$ bits
- 3×slower than DES
- Simple attack in time: $\approx 2^{118}$

$k_1 = k_2 = k_3 \Rightarrow \text{DES}$

Meet-in-the-Middle attack on 3k3DES(EDE):

Time = 2^{118} , Space $\approx 2^{56}$

Concerns about DES

- Short key length
 - DES “cracker”, built for \$250K, can break DES in days
 - Distributing the computation makes it faster
- Some (theoretical) attacks have been found
- Non-public design process
- 3-DES is fairly slow

Thank You !

See You Next Week...